

Plantilla de Excel para Cálculo de IGM y ROI

Diseño lógico para implementación en hoja de cálculo

Este documento describe cómo estructurar una hoja Excel (o equivalente) para calcular:

- Un Índice Global de Madurez (IGM) en modelado de amenazas y gestión de riesgo.
- Indicadores simples de ROI o “valor financiero estimado” de las mejoras.

1. Estructura de pestañas

Se recomiendan, al menos, las siguientes hojas:

1. RESPUESTAS
2. PONDERACIONES
3. CALCULOS_IGM
4. ROI
5. GLOSARIO

2. Hoja RESPUESTAS

Columnas sugeridas:

- A: ID_Organizacion
- B: Fecha_Respuesta
- C: Sector
- D: Tamaño
- E: Campo_Pregunta (ej. 2.1.1)
- F: Valor_Respuesta (numérico o codificado)

Opcionalmente, se puede estructurar cada organización en una sola fila con columnas por pregunta, pero la estructura por filas es más flexible para análisis.

3. Hoja PONDERACIONES

Columnas:

- A: Campo_Pregunta (ej. 2.1.1)
- B: Dimension (GOV, TM, VULN_SIM, RISK_ROI, CAP)
- C: Peso_en_dimension (0–1, suma = 1 por dimensión)
- D: Tipo_Pregunta (Likert, Categórica, Binaria)
- E: Mapeo_Respuesta_a_0_100 (texto describiendo la regla)

Ejemplo de reglas de mapeo:

- Likert 1-5 -> 0, 25, 50, 75, 100
- Categórica (p.ej. “pleno”, “parcial”, “no”):
- Pleno = 100
- Parcial = 60
- En elaboración = 40
- No = 0

4. Hoja **CALCULOS_IGM**

Para cada organización:

- Calcular puntuación normalizada por pregunta: $\text{Punt_Pregunta} = \text{Valor_Normalizado}_{0_100}$.
- Calcular subíndices:
- $\text{GOV} = \text{SUMA}(\text{Punt_Pregunta} * \text{Peso_en_dimension})$ para todas las preguntas GOV.
- Igual para TM, VULN_SIM, RISK_ROI, CAP.
- Calcular IGM:

Calcular subíndices:

$\text{GOV} = \text{SUMA}(\text{Punt_Pregunta} * \text{Peso_en_dimension})$ para todas las preguntas GOV.

Igual para TM, VULN_SIM, RISK_ROI, CAP.

Calcular IGM:

$$\text{IGM} = (\text{GOV} * w_{\text{GOV}}) + (\text{TM} * w_{\text{TM}}) + (\text{VULN_SIM} * w_{\text{VS}}) + (\text{RISK_ROI} * w_{\text{RR}}) + (\text{CAP} * w_{\text{CAP}})$$

Donde:

- $w_{\text{GOV}}, w_{\text{TM}}, w_{\text{VS}}, w_{\text{RR}}, w_{\text{CAP}} \in [0,1]$ y su suma = 1.
- Ejemplo inicial (ajustable):
- $w_{\text{GOV}} = 0,20$
- $w_{\text{TM}} = 0,30$
- $w_{\text{VS}} = 0,20$
- $w_{\text{RR}} = 0,15$
- $w_{\text{CAP}} = 0,15$

5. Hoja ROI

El ROI en ciberseguridad, y en particular en modelado de amenazas, es difícil de medir, pero se puede aproximar con:

6. Estimación del riesgo anual esperado antes y después de las mejoras.
7. Coste directo de las mejoras.

Columnas:

- A: ID_Organizacion
- B: Riesgo_Anual_Esperado_Baseline (€)
- C: Riesgo_Anual_Esperado_Actual (€)
- D: Inversion_Anual_Modelado_Threat_Modeling (€)
- E: Ahorro_Anual_Estimado (€) = B – C
- F: ROI (%) = (E – D) / D * 100

Donde:

- Riesgo_Anual_Esperado puede estimarse a partir de:
- Historial de incidentes.
- Escenarios PASTA de alto riesgo con probabilidad x impacto.
- Benchmarks internos o sectoriales.

Como atajo, se puede usar una fórmula heurística:

$$\text{Riesgo_Anual_Esperado_Actual} = \text{Riesgo_Anual_Esperado_Baseline} * (1 - \text{Reduccion_Riesgo_Por_Mejora})$$

Y Reduccion_Riesgo_Por_Mejora se puede aproximar como una función del incremento en el IGM (por ejemplo, cada 10 puntos de aumento en IGM suponen un X % de reducción de riesgo, ajustado por sector).

6. Hoja GLOSARIO

Definir:

- IGM y sus dimensiones.
- ROI y sus limitaciones.
- Criterios de normalización (cómo se convierten las respuestas en 0–100).
- Referencias a marcos usados (PASTA, STRIDE, NIS2, etc.).[web:18][web:21][web:31]

Esta plantilla no pretende ser el evangelio definitivo del cálculo de ROI en ciberseguridad, pero sí un punto de partida honesto para pasar de la sensación a la medición.